

Security Awareness -- Guided Notes ANSWER KEY

Unit tp-6.9 | CompTIA Network+ N10-009 Obj. FC0-U71 6.2 | N10-008 FC0-U71 6.2

For instructor use / distribute after students complete the notes.

Question 1

Security awareness training teaches employees to recognize and _____ to security threats. The most common attack vector that bypasses all technical controls is _____ engineering -- manipulating _____ rather than systems. Organizations with high security awareness have _____ breach rates than those without training.

Answer: Respond; social; people; lower.

Question 2

Social engineering attacks exploit human _____ (wanting to help), _____ (acting fast without thinking), _____ (following authority figures), and _____ (doing what others do). Recognizing these psychological triggers is the first step in _____ them.

Answer: Helpfulness; urgency; authority; social proof; resisting.

Question 3

Phishing emails often: use _____ sender addresses that look legitimate at first glance, create a sense of _____ ('act now or your account will be closed'), contain _____ to malicious websites, and request _____ or financial information. The red flag test: a legitimate organization will never ask for your password via _____.

Answer: Spoofed; urgency; links (URLs); credentials; email.

Question 4

Pretexting is when an attacker creates a fake _____ to manipulate a target. For example, an attacker calls IT support pretending to be a _____ and asks for a password reset. A _____ attack physically follows an authorized person through a secure door. _____ involves leaving infected USB drives where employees will find and plug them in.

Answer: Scenario (story); manager/executive; tailgating (piggybacking); baiting.

Question 5

Security awareness programs should include: _____ training for new employees, _____ refresher training throughout the year, _____ phishing simulations (fake phishing emails sent to employees to test their response), and _____ reporting procedures (clear instructions on how to report suspicious activity).

Answer: Onboarding; recurring (periodic); simulated; clear.

Question 6

An insider _____ is a current or former employee who intentionally or accidentally causes harm. _____ insider threats are employees who deliberately steal data or sabotage systems. _____

insider threats are employees who accidentally cause breaches (clicking phishing links, misconfiguring systems). Both types are addressed partially through awareness _____.

Answer: Threat; malicious; negligent; training.

Question 7

Clean desk policy requires employees to clear _____ documents from their desk when not at it. Screen _____ software locks the screen after a period of inactivity. _____ filters make it difficult to read a screen from the side, preventing shoulder _____ in public spaces. These physical security measures support _____ confidentiality.

Answer: Sensitive; lock (saver); Privacy; surfing; data.

Question 8 -- Real World Application

REAL WORLD: An attacker calls a bank employee and says: 'Hi, this is Mike from IT security. We had a breach last night and I need to urgently verify your credentials to protect your account. Can you give me your username and password?' The employee, panicked by the word 'breach,' complies. Identify the social engineering techniques being used and describe what the employee should have done instead.

Answer: Social engineering techniques used: (1) Authority: the attacker claims to be from IT security, a trusted internal authority. Employees are conditioned to comply with IT requests. (2) Urgency/fear: mentioning a breach create panic and time pressure that bypasses rational thinking -- the employee feels they must act immediately. (3) Pretexting: the attacker constructed a plausible false scenario (post-breach credential verification) to justify the unusual request. What the employee should do: (1) Never provide credentials over the phone -- legitimate IT staff never need your password. They can reset it without you verifying it verbally. (2) Verify the caller's identity through a separate channel: hang up and call the IT help desk directly using the number from the company directory (not a number the caller provides). Ask if Mike from IT security made this call. (3) Report the attempt to the security team immediately -- this is a live attack. The goal is to identify and report, not argue with the attacker.